

Generative AI and Next-Generation Cyber Defense Strategies

Evolving the Defensive Mindset

Modern cyber defense requires a shift in mindset. Rather than trying (and inevitably failing) to **eliminate every vulnerability**, defenders must focus on **detecting and responding to attacker activity**. No organization can perfectly “patch everything” or prevent every breach attempt – and luckily, they don’t have to. Attackers are human (or human-programmed) and **always make mistakes** during their intrusion attempts ¹. In fact, real-world breaches involve multiple steps and missteps; the “*one click and you’re gone*” scenario is an oversimplification. Effective security today assumes that some attacks will get in, so the goal is to *spot the anomalies early and react quickly*. This approach aligns with the “assume breach” philosophy and **defense-in-depth**: even if one layer fails, monitoring and response can catch adversaries before they reach the “crown jewels.” As one security researcher notes, attackers often wander networks chasing dead ends, making noise because they lack perfect insider knowledge ¹. The defender’s advantage lies in knowing their environment and **watching for those deviations**.

In practical terms, this means building systems that **log and detect** suspicious behavior and having processes in place to respond when something looks off. It’s acceptable (and realistic) to have some security gaps, as long as you can **catch intruders in the act**. Every attempted attack presents opportunities to catch the attacker’s errors – whether it’s an unusual login, a process running where it shouldn’t, or data moving at odd times. The **key challenge for defenders** is to react swiftly when such warning signs appear, containing incidents before they escalate. Ultimately, the measure of a robust defense is not zero incidents, but the **speed and efficiency of detection, response, and recovery**.

Mapping Processes and Assets with GenAI for Situational Awareness

One foundational defensive capability is **knowing exactly how your business works** – your processes, assets, and interdependencies. Today, many organizations struggle with outdated documentation and siloed tribal knowledge. **Generative AI (GenAI)** can play a game-changing role here by ingesting existing data (documents, tickets, code, configs) and producing up-to-date process maps, workflows, and system descriptions. Large language models excel at analyzing and transforming information, which means they can help generate accurate documentation where little existed before. By leveraging GenAI to document “**who does what, how, and with which systems**”, a company can achieve much better **situational awareness** of its internal environment. This includes mapping business processes, data flows, and identifying critical assets – the “**crown jewels**” that attackers would target.

Example: A knowledge graph representing an organization’s IT environment, showing how systems, users, and data are connected. Such a knowledge graph acts as a digital twin of the enterprise, providing a holistic view for defenders ² ³.

To enable this, organizations are turning to **knowledge graphs and semantic networks**. A knowledge graph can integrate data from many sources to form a connected map of the environment – for example, which systems talk to each other, which user accounts have access to which applications, and

where the most sensitive data resides ³ . Critically, these graphs can also incorporate real-time context like vulnerabilities or incidents mapped to the assets they affect. The goal is an **ontology of ontologies** – each team or domain can maintain its own data model, but a semantic graph links them together. This approach avoids reinventing the wheel in each silo and instead **connects the dots** between business process definitions, IT systems, security controls, and so on.

It's important to note that GenAI and knowledge graphs would be used **to build and maintain this situational picture**, but not necessarily be in-line for every real-time decision. In practice, once you've **modeled your environment** (with heavy AI assistance in parsing data), the actual monitoring and controls can be handled by more deterministic code and queries. GenAI helps “shortcut” the creation of these maps and documentation, which historically was very labor-intensive and error-prone. With an accurate, AI-updated map of the organization, security teams gain **true visibility**: they know what “normal” looks like and can more readily spot abnormal patterns. This situational awareness is invaluable for prioritizing defenses around the most important assets and understanding the potential impact if something goes wrong.

Incident Response Augmented by Generative AI

Even with the best preventive measures, incidents will happen – and how you handle them makes all the difference. Generative AI can significantly enhance **incident response (IR)** and crisis management. One way is by acting as a **real-time documentation and communication assistant**. During an incident, there's a flood of information: logs, alerts, analyst notes, emails, etc. LLMs can quickly summarize and organize this information, ensuring that **nothing slips through the cracks**. They can also help draft updates or reports for different audiences (from technical teams to executives), saving responders huge amounts of time. In fact, Google's security team found that using GenAI to draft incident summaries **cut writing time by over 50% while actually improving quality** ⁴ . In an experiment, AI-generated incident reports were rated as **10% more complete** than human-written ones, on average, and were produced in half the time ⁵ .

This means an incident commander can have the AI **quickly produce a situation report** or stakeholder briefing, which they then review and tweak. By automating the drudgery of report writing, responders stay focused on analysis and containment – the tasks that truly require human judgment. GenAI can also assist in tracking incident timelines, suggesting next steps from playbooks, and ensuring **post-mortem documentation** is thorough. Services are already emerging that generate **in-depth post-incident reports** automatically, so teams can learn and improve faster ⁶ .

Another benefit is in **stakeholder communication**. During a crisis, executives and cross-functional partners need frequent updates. AI can tailor the messaging to each stakeholder group (e.g. a non-technical summary for executives vs. a technical analysis for IT teams) instantly, based on one source of truth. This ensures everyone gets a clear, consistent story of what's happening and what's being done. Effective communication prevents panic and keeps all teams aligned, which is often half the battle in incident management.

However, it's crucial that GenAI is used with human oversight in IR. The **final decisions and approvals** must rest with the incident response team, and any AI-generated content should be reviewed for accuracy. The power of GenAI here is as an accelerator and force-multiplier – turning raw data into actionable summaries or draft action plans in seconds. With this augmentation, an incident that might have taken days to triage and contain can potentially be dealt with in hours or even minutes, simply because the team has **better information and coordination** at their fingertips. In summary, every incident (or even near-miss) becomes an opportunity to **practice, document, and harden** the

organization's response muscles, and AI helps capture those lessons so the organization gets stronger after each event.

Data-Driven Risk Management with AI and Graphs

Closely tied to both prevention and response is the discipline of **risk management**. Unfortunately, in many companies today risk management is still handled in a very ad-hoc way – often relegated to Excel spreadsheets and periodic meetings. These manual, fragmented approaches make it hard to get a clear picture of the organization's risk landscape or to **prioritize investments** effectively. In fact, relying on spreadsheets for cybersecurity and compliance management can itself become *"a liability"* – it introduces delays, errors, and inconsistency, making scalable and consistent risk management nearly impossible ⁷. GenAI and modern data tools can change this by bringing **automation, evidence, and integration** to risk management.

Imagine feeding all your audit findings, vulnerability scan results, incident records, and business impact analyses into a **central AI-assisted risk platform**. The AI could help correlate related risks, attach real evidence (e.g. *"System X is missing critical patches"* with links to actual scan data), and even quantify potential impacts. Moreover, by using a **graph-based approach**, each risk can be contextualized – linked to the assets, business processes, and controls it affects. This creates a **"risk graph"** that shows how a potential threat could propagate to business impact. With this, security leaders and business stakeholders can **visualize trade-offs**: for example, how a decision to delay a security upgrade might increase risk to a critical revenue system.

A powerful concept here is to require **explicit risk acceptance** for all identified risks. In other words, if something is known to be a risk (unpatched server, a policy exception, etc.), it must be recorded and formally accepted by the responsible party for a specific timeframe. The question is not *"can we eliminate all risk?"* – it's *"who is accepting the risk, and for how long?"*. For instance, a high-severity vulnerability might be only accepted for 48 hours (meaning it must be fixed or mitigated quickly), whereas a lower risk might be accepted for 6 months with a plan. By **time-boxing risk acceptance**, you create accountability and urgency where needed. All these accepted risks live in the system with owners, evidence, and expiration dates, forcing continuous re-evaluation. This practice can be aided by AI through automated reminders, aggregation of evidence, and even recommendations on which risks are most pressing based on evolving threat intelligence.

Ultimately, an AI-enhanced risk management approach means **better conversations with the business**. When the security team can present a data-driven risk profile – *"Here are our top 5 risks, here's what they affect, here's what mitigating them would cost versus the potential impact of not mitigating"* – it elevates the discussion from fear-based to fact-based. Business leaders can then make informed decisions: consciously accept certain risks, fund certain mitigations, or adjust strategies. Over time, this builds a culture where **risk is continuously monitored and managed**, not just reviewed once a year. It also aligns everyone on the reality that cybersecurity is a business decision process: you can't do everything at once, but with good data you can **do the most important things first**.

Adaptive Compliance and Regulatory Alignment

The compliance landscape in cybersecurity has grown increasingly complex – companies face a maze of standards, laws, and frameworks (PCI, GDPR, ISO, NIST CSF, and many more). A common complaint is that these standards **overlap and often conflict**, creating huge overhead. For example, a U.S. Government study found that when critical infrastructure operators had to follow multiple regulators' rules, *"the result [was] conflicting guidance, inconsistencies, and redundancies."* In one case, **49% to 79% of**

the requirements overlapped or conflicted across frameworks, greatly increasing the time and effort needed for compliance ⁸ ⁹. This one-size-fits-all, checklist-based approach clearly does not scale well – it burdens smaller firms and doesn't necessarily reduce real risk. We need a way to **scale and tailor compliance** efforts to each organization's context, and GenAI can help get us there.

One vision is **customized, dynamic compliance** programs. Instead of treating compliance as a static checklist, organizations can use AI to interpret the intent behind regulations ("the *why*") and map those to their own controls and risks. This is where the earlier **semantic graphs** concept extends into compliance: imagine a "compliance graph" that links each regulation or standard to the actual evidence of compliance within the company (policies, control implementations, audit results). GenAI could assist by reading through lengthy regulation text and summarizing what a particular business unit needs to do to comply, given its specific operations. It could also highlight overlaps – e.g., *"Implementing control X will satisfy requirement Y from GDPR and requirement Z from ISO 27001."* In essence, **AI can help translate generic regulations into a personalized set of requirements and controls** for an entity, reducing the noise and focusing on what truly matters for that entity's risk profile.

We are likely to see regulatory bodies themselves embrace more **outcome-based and flexible compliance criteria**. Instead of everyone following identical checklists, an organization could demonstrate that it meets the *intent* of regulations through equivalent controls that make sense for its size and technology. AI and automation would be key in **tracking and reporting this compliance in real-time**. When all your controls and risks are represented in a graph, it's much easier to generate on-demand reports: e.g., show how a new software deployment affects your compliance with a certain framework. Over time, this could even enable **continuous compliance monitoring**, where gaps are flagged as they emerge (instead of after the fact in an audit).

Crucially, scaling compliance in this way will require close integration with the earlier risk management approach. Compliance mandates shouldn't be seen as separate from security risk; they are often legal/industry *expressions* of minimum acceptable security. By linking compliance requirements directly to your risk and security activities (via that semantic graph), you ensure that **every security improvement translates into compliance improvements** (and you can prove it). For instance, if a company strengthens its encryption and access controls on customer data, an AI-driven system could automatically show how this action improves compliance with GDPR *and* PCI DSS, etc. This creates positive reinforcement to do the right security things, because you can immediately see the multi-faceted benefits (risk reduced, multiple compliance checkboxes ticked, customers and regulators happier). In summary, GenAI can help tame the complexity of compliance by **mapping the many-to-many relationships** between controls and standards, and producing a customised, efficient compliance program for each organization.

Cyber Insurance as a Security Driver

When it comes to managing residual risk, **cyber insurance** plays an increasingly significant role. Cyber insurance basically allows a business to transfer some financial risk of breaches to an insurer, but its influence goes beyond just payouts. Insurers today are effectively becoming **security stakeholders**: they often require clients to implement certain baseline controls to qualify for coverage, and they incentivize better security with lower premiums or higher coverage limits. In this way, insurance acts as both a **"stick" and a "carrot"** for cybersecurity ¹⁰. A recent industry report noted that by *"setting minimum security control requirements to attain coverage — the 'stick' — the insurance industry is effectively forcing many organizations to elevate their cyber defenses. In parallel, [by] rewarding strong defenses through lower premiums and improved terms, cyber insurers are incentivizing risk reduction through superior*

protection.”¹⁰ In short, if you invest in better security, you not only reduce your breach risk but often pay less for insurance – a win-win that savvy business leaders are starting to recognize.

In the future, we may see **more granular (“micro”) insurance products** tailored to specific risks or business segments. For example, a company might buy a special policy for risks associated with a critical cloud service, or a manufacturing firm might insure its operational technology (OT) systems separately. This aligns with the earlier idea of treating each risk individually and either mitigating or accepting (transferring) it. If certain risks are hard or expensive to mitigate technically, insurance can be the financial control that makes the risk acceptable. GenAI can assist insurers in **analyzing a client’s security posture** quickly (scanning network data, configurations, etc. to assess risk), which could lead to more dynamic pricing and coverage. For businesses, AI can help determine the **optimal mix of controls vs. insurance** – essentially performing cost-benefit analysis: “*Would it be cheaper to implement control X or to insure against the outcome of not implementing it?*” Those kinds of analyses can get very complex, but AI is well-suited to digesting large amounts of data and estimating probabilities from historical breach data, industry trends, etc.

Cyber insurance is also becoming a factor in **third-party risk management**. When evaluating vendors or partners, companies might start asking for proof of cyber insurance or even the *rates* they pay. The logic being: if an insurer (with their access to underwriting data) deems a vendor high-risk (and thus charges high premiums or refuses coverage), that’s a red flag for the vendor’s security practices. Conversely, a well-insured vendor with good terms has effectively been vetted to some degree. We could envision a future where certain ecosystems require participants to carry cyber insurance, much like contractors needing to be bonded/insured in construction – it raises the baseline security for everyone.

Liability and Transparency for Software Security

An important development in cybersecurity strategy is the push for greater **liability on software producers** and more transparency about software components. For too long, software and device makers have had little accountability for insecurities in their products. That is starting to change. Governments are considering (and in some cases enacting) laws that **shift more responsibility onto vendors** for shipping insecure products. For example, the 2023 U.S. National Cybersecurity Strategy explicitly calls to “*begin to shift liability onto those entities that fail to take reasonable precautions to secure their software.*”¹¹ The idea is straightforward: if a company is selling software that underpins critical services, it should bear the cost when negligence in security leads to harm, rather than the customers or end-users bearing all the consequences. In the EU, similarly, new regulations like the Cyber Resilience Act and updates to product liability directives are introducing stricter **liability for digital products**, including software and AI systems, effectively forcing manufacturers to build in security or face legal and financial penalties¹².

Hand-in-hand with liability is the need for **transparency** in software. One initiative gaining traction is the *Software Bill of Materials (SBOM)* – essentially a nutritional label for software that lists its components (libraries, dependencies, versions). SBOMs help organizations understand if they are using software that contains known vulnerabilities (for example, if a certain library has a flaw, you can quickly search all SBOMs to find which applications rely on it). We expect the next generation of SBOMs to be more **comprehensive and machine-readable**, possibly incorporating semantic knowledge (graphs) linking components to known issues, licenses, and other metadata. Beyond SBOMs, there’s a broader push for **security labels** on tech products. A notable example is the new *U.S. Cyber Trust Mark* program for consumer IoT devices, announced in 2023. This is a **voluntary cybersecurity certification and labeling** initiative so that IoT products meeting strong security criteria can bear a special “Cyber Trust”

label ¹³ . The goal is to inform consumers (and businesses) which products are built securely – akin to an “Energy Star” label but for cyber safety. Over time, widespread adoption of such labels could make security a market differentiator and **increase accountability** for manufacturers (since a label implies a standard that must be maintained).

Generative AI and knowledge graphs will assist in these transparency efforts by automating the collection and analysis of software supply chain data. For instance, an AI could continuously scan public vulnerability data and cross-reference it with an organization’s SBOMs and asset inventory, alerting when a new flaw affects one of the components in use. Similarly, AI can help regulators sift through compliance reports or incident reports to identify vendors who repeatedly have issues, potentially informing liability actions. Ultimately, by coupling **enforced liability** with **greater transparency (SBOMs, labels)**, the industry creates a feedback loop: companies will invest more in secure development up front, knowing they can’t hide problems easily and will be on the hook if things go wrong. This, in turn, reduces the systemic risk and shifts the advantage back toward security defenders over the long run.

Strengthening Technical Foundations: Data and Identity

All the strategy and AI in the world still rests on having a robust technical foundation. Two areas needing significant improvement are **data storage integrity** and **identity/access management**, especially as we brace for AI-driven attacks.

First, we need to **rethink our data stores and databases** with security and resilience in mind. Many current database systems were not designed with cyberattacks or AI-enabled manipulation in mind – they may lack built-in versioning, tamper-evident logs, or easy recovery mechanisms. Going forward, it’s crucial to have data stores that can **withstand corruption and quickly roll back** when something bad happens. For example, implementing *immutable data logs* or version-controlled data (so any change is an append-only operation that can be audited) can make it much harder for an attacker or errant AI to maliciously alter records without detection ¹⁴ ¹⁵ . Some experts even advocate **using the file system itself as a simple database** (with structured files for records) because it can encourage simpler designs and allow leveraging standard version control and backup tools. The simpler the data architecture, the smaller the attack surface – and simplicity often correlates with reliability. In practice, whether it’s a traditional database or a filesystem approach, the focus should be on *traceability* (know who/what changed data and when), *rapid recoverability* (point-in-time restore, partial restores), and even the ability to **“air gap” or slow down** certain high-value data changes so they can be reviewed. AI can help monitor data integrity – for instance, detecting anomalies in data patterns that might indicate corruption or unauthorized modification.

Second, and perhaps most importantly, is **Identity and Access Management (IAM)**. In a world of automated attacks, the principle of **least privilege** becomes non-negotiable. Every user, system, or AI agent should have the minimal access necessary for its function, and no more. Strong IAM practices can drastically **limit the blast radius** of an attack. If one account is compromised, strict privileges and network segmentation should ensure the attacker can’t easily pivot to broader systems. As Google’s security framework describes it, giving identities only least-privilege access **“helps to limit the scope of damage if and when a breach does occur,”** containing threats and minimizing further exposure ¹⁶ . Achieving this at scale means leveraging **graph-based identity models** – effectively mapping relationships between identities (people, machines, service accounts), their roles, and the resources they can access. Modern IAM solutions and “zero trust” architectures already encourage this: every access request is continuously evaluated in context (Who is the user? What are they accessing? From

where? Is it normal for them?). By mapping these relationships in a graph, one can quickly analyze, for example, “if account X is taken over, what could it possibly reach?” and put guardrails in place.

GenAI can assist in IAM by analyzing usage patterns to recommend tighter policies (for example, noticing that a user never uses a certain permission and flagging that permission for removal). It can also help developers by writing **infrastructure-as-code for IAM configurations**, which is less error-prone than manual setups. The bottom line: **strong identity controls and granular permissions** are the safety net that prevents isolated incidents from turning into full-blown breaches. As attacks accelerate in speed (with AI, an attacker might rapidly test every credential or try thousands of lateral movements), only automated, fine-grained identity enforcement will keep up. Investing in these controls now – and using AI to continuously audit and improve them – is one of the best ways to future-proof your defenses.

Conclusion

In summary, the next evolution of cyber defense will blend **human strategy, improved processes, and AI-driven automation**. We will no longer play “whack-a-mole” trying to patch every hole; instead, we’ll accept that some holes exist and focus on catching the adversary in the act by leveraging our home-court knowledge of our systems. Generative AI will be our ally in this, giving us unprecedented visibility into our complex organizations and speeding up everything from incident response to compliance. By embracing knowledge graphs and AI, defenders can finally integrate the business context – knowing what is most important to protect and how everything is connected. This allows prioritization of effort where it truly matters.

Furthermore, by tying together risk management, compliance, and even insurance, security leaders can **speak the language of business** and drive cybersecurity from a cost center to a board-level strategic function. In fact, as was pointed out, a CISO of the future isn’t just managing firewalls – they’re helping steer the company by informing decisions with cyber risk insight. It’s even conceivable that **CISOs should sit on corporate boards** not only to champion security, but to provide guidance on resilience, continuity, and technology-driven business strategy. Cybersecurity, after all, now touches every facet of a modern business.

The threat landscape will keep getting tougher – attackers are automating, using AI, and moving faster than ever. But defenders are not standing still. With the approaches outlined – from AI-augmented process mapping and incident response, to dynamic risk and compliance management, to leveraging market forces like insurance and liability – we have a fighting chance to **stay ahead of the curve**. It’s a time of great challenge, but also great opportunity: by rethinking our defenses and intelligently applying new tools, we can build organizations that are not only harder to breach, but also **nimble and resilient** in the face of any cyber adversity.

Sources:

- Lefevers, W. *Insider knowledge: A defender’s greatest advantage against attackers*. Cybereason (2019) ¹.
- Neo4j Team. *Graphs for Cybersecurity: Knowledge Graph as Digital Twin*. Neo4j Blog (2022) ² ³.
- Rosique, L. et al. *Accelerating incident response using generative AI*. Google Security Blog (2024) ⁴ ⁵.
- Cynomi (T. Tal). *Still Using Spreadsheets to Manage Cyber Risk? That’s Your First Risk*. Cynomi Blog (2025) ⁷.
- U.S. GAO. *Cybersecurity: Efforts Initiated to Harmonize Regulations...* (2024) ⁸ ⁹.

- R&I Editorial Team. *Cyber Insurance Provides Both Carrot and Stick for Cyber Security* (Sophos research) (2024) ¹⁰ .
- White House. *National Cybersecurity Strategy* (2023) ¹¹ .
- UL Solutions. *Guide to the U.S. Cyber Trust Mark* (2023) ¹³ .
- Google Cloud. *Zero Trust: Benefits of Least Privilege*. (n.d.) ¹⁶ .

¹ Insider knowledge: A defender's greatest advantage against attackers

<https://www.cybereason.com/blog/insider-knowledge-a-defenders-greatest-advantage-against-attackers>

² ³ Graphs for Cybersecurity: Knowledge Graph as Digital Twin

<https://neo4j.com/blog/security/graphs-cybersecurity-knowledge-graph-digital-twin/>

⁴ ⁵ Google Online Security Blog: Accelerating incident response using generative AI

<https://security.googleblog.com/2024/04/accelerating-incident-response-using.html>

⁶ Generative AI & Incident Management Guide - ilert

<https://www.ilert.com/generative-ai-incident-management-guide>

⁷ Still Using Spreadsheets to Manage Cyber Risk? That's Your First Risk - Cynomi

<https://cynomi.com/blog/still-using-spreadsheets-to-manage-cyber-risk/>

⁸ ⁹ GAO-24-107602, CYBERSECURITY: Efforts Initiated to Harmonize Regulations, but Significant Work Remains

<https://www.gao.gov/assets/gao-24-107602.pdf>

¹⁰ Cyber Insurance Provides Both Carrot and Stick for Cyber Security - Risk & Insurance : Risk & Insurance

<https://riskandinsurance.com/cyber-insurance-provides-both-carrot-and-stick-for-cyber-security/>

¹¹ bidenwhitehouse.archives.gov

<https://bidenwhitehouse.archives.gov/wp-content/uploads/2023/03/National-Cybersecurity-Strategy-2023.pdf>

¹² Attention CISOs: The New EU PLD Is Effective Now - Hyperproof

<https://hyperproof.io/resource/eu-pld-effective-now/>

¹³ UL Solutions Guide to the U.S. Cyber Trust Mark | UL Solutions

<https://www.ul.com/insights/us-cyber-trust-mark>

¹⁴ The importance of immutable and tamper-proof data in compliance

<https://log-locker.com/en/blog/the-importance-of-immutable-and-tamper-proof-data-in-compliance>

¹⁵ Immutable Storage Is Here—And It's Making Hackers Sweat

https://estore.flexxon.com/blogs/immutable-storage/immutable-storage-is-here-and-it-s-making-hackers-sweat?srsltid=AfmBOooy2KCixgDnCFSeb1sGK_eG0YrS7z9tUhIRMgfjsgP3df2RyWQa

¹⁶ What is Zero Trust? | Google Cloud

<https://cloud.google.com/learn/what-is-zero-trust>